

《信息安全综合实验》实验报告

实验 3: WPA/WPA2 协议分析实验

姓名: 蒋衲言 学号: 2313546

1 实验目的

1. 理解 WPA/WPA2-PSK 协议的基本原理。
2. 掌握四次握手过程的详细流程。
3. 使用 Wireshark 等工具捕获握手包。
4. 分析 EAPOL-Key 帧的结构和字段。
5. 探讨 KRACK 等针对握手协议的安全攻击。

2 实验环境

2.1 硬件

- 无线网卡: 电脑自带的无线网卡即可, 无需特殊功能。
- 智能手机: 用于开启热点, 支持 WPA2-PSK, 如图1所示。
- 电脑 (Windows 11 系统): 运行抓包工具。



图 1: 手机热点配置

2.2 软件

- Wireshark：图形化协议分析工具，可解析 EAPOL 帧。
- Microsoft Network Monitor：Windows 平台网络分析工具
(访问 <https://www.microsoft.com/en-us/download/details.aspx?id=4865> 下载，如图2所示)。

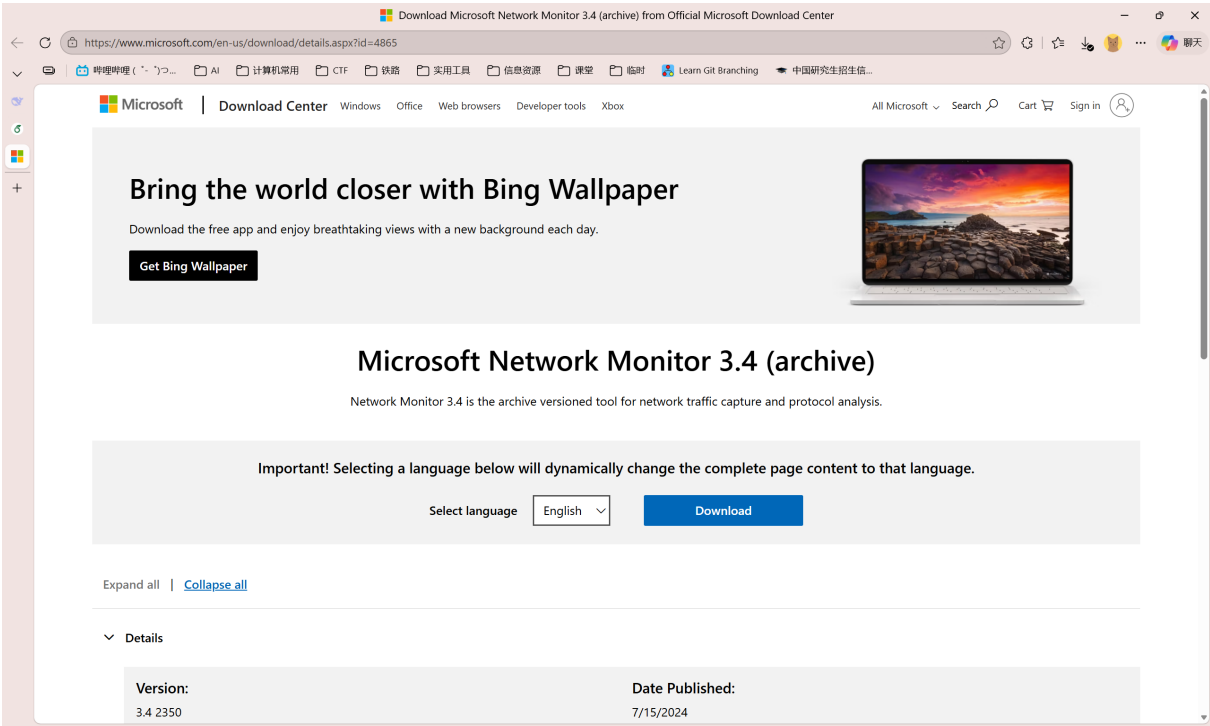


图 2: 下载 Microsoft Network Monitor

3 实验原理

WPA (Wi-Fi Protected Access) 是一种无线局域网的安全协议，用来保护无线通信不被窃听或篡改。它是为了修复早期 WEP 协议严重漏洞而推出的过渡方案。本次实验重点关注 WPA/WPA2-PSK 模式，这也是手机热点普遍采用的模式。在 PSK 模式下，所有连接设备共享同一个密码，协议通过四次握手过程派生会话密钥，确保每个连接使用独立的加密密钥。下面详细解释四次握手的过程。

几种关键密钥概念

名称	全称	作用	是否用于加密	谁生成
PSK	Pre-Shared Key (预共享密钥)	用户输入的 WiFi 密码	否	用户/管理员
PMK	Pairwise Master Key (成对主密钥)	四次握手的根密钥	否	由 PSK 推导
PTK	Pairwise Transient Key (成对临时密钥)	单播通信加密密钥集合	是	双方协商生成
GTK	Group Temporal Key (组临时密钥)	广播/组播通信加密	是	AP

客户端输入 WiFi 密码 (PSK) 后, 计算出根密钥 PMK, 而 AP 同样可以计算出 PMK, 故在四次握手之前, 双方已经同时拥有 PMK。

第一次: AP 发送 ANonce

AP 生成一个随机数 ANonce, 然后发给客户端。目的是把 AP 的随机性提供给客户端, 让客户端后面能参与计算 PTK。

第二次: 客户端发送 SNonce + MIC

客户端生成自己的随机数 SNonce, 根据 PMK、ANonce、SNonce、双方 MAC 计算出 PTK, 用 PTK 中的 KCK 对整个第 2 条 EAPOL-Key 报文 (除 MIC 字段本身) 计算一个完整性校验值 MIC (Message Integrity Code), 然后把 SNonce 和 MIC 发给 AP。

第三次: AP 发送 GTK + MIC

AP 在验证完第 2 条消息的 MIC 后, 说明 AP 已经确认客户端没问题。此时 AP 也算出了 PTK, 然后生成或取出当前网络使用的 GTK, 用 PTK 中的 KEK 对 GTK 进行加密, 再用 KCK 对整条消息计算 MIC, 最后把这条消息发给客户端。

第四次: 客户端确认安装完成

客户端收到第 3 条消息后用自己算出的 PTK 验证 MIC, 若验证成功, 说明 AP 也知道正确 PMK。于是用 KEK 解开 GTK, 安装 PTK (用于和 AP 的单播通信) 和 GTK (用于广播/组播接收)。客户端安装好 PTK/GTK 后, 向 AP 发送第 4 条确认消息, 这条消息也会带 MIC, 表明其已经成功安装密钥, 现在可以开始正式加密通信了。AP 收到后验证 MIC 正确, 就认为整个四次握手结束。

此时双方都已经拥有一致的 PTK, 客户端拿到了 GTK, 密钥都已安装完成。整个过程如图3所示。

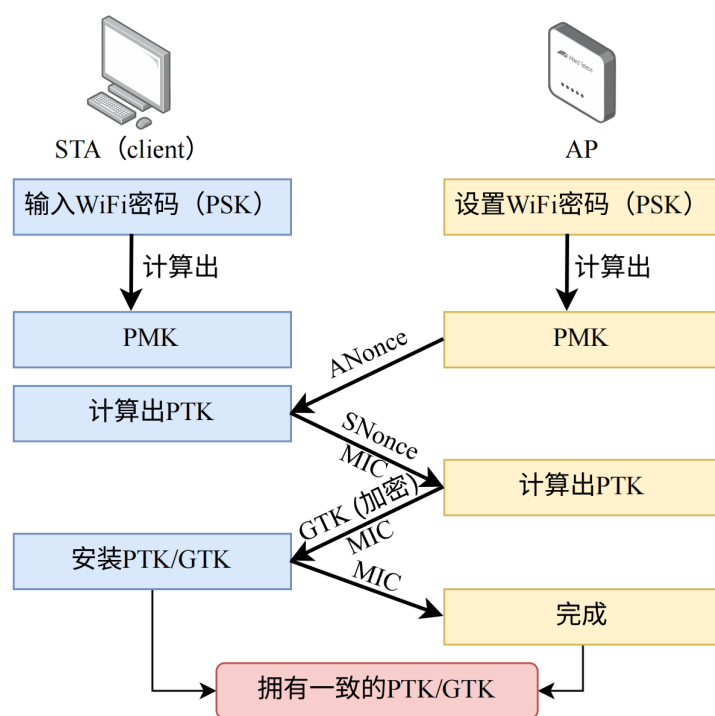


图 3: 四次握手过程

4 实验步骤

以管理员身份运行 Microsoft Network Monitor，选择网卡 WLAN，开启抓包。然后在电脑上连接手机热点，输入密码。首次连接成功后，抓包工具应显示包含 4 个 EAPOL-Key 帧的捕获内容，将捕获内容保存为 test.cap，如图4所示。

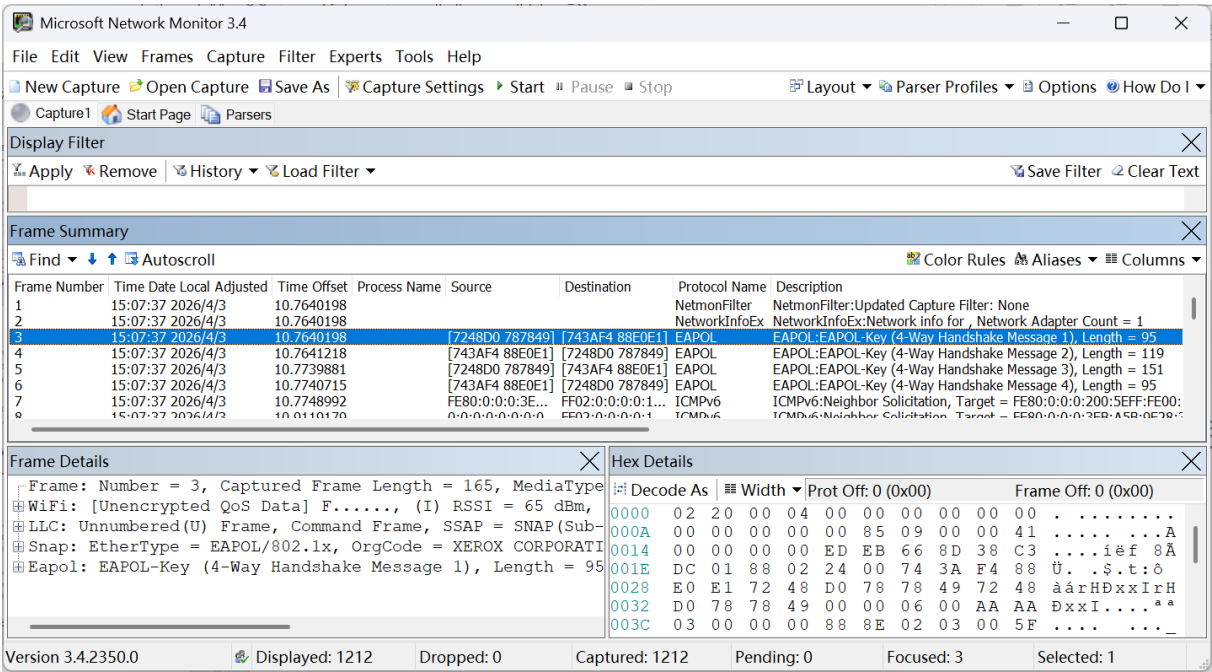


图 4: 抓包得到 4 个 EAPOL-Key 帧

5 抓包分析

用 Wireshark 打开 test.cap，在过滤器中输入 eapol 过滤 EAPOL 帧，如图5所示。

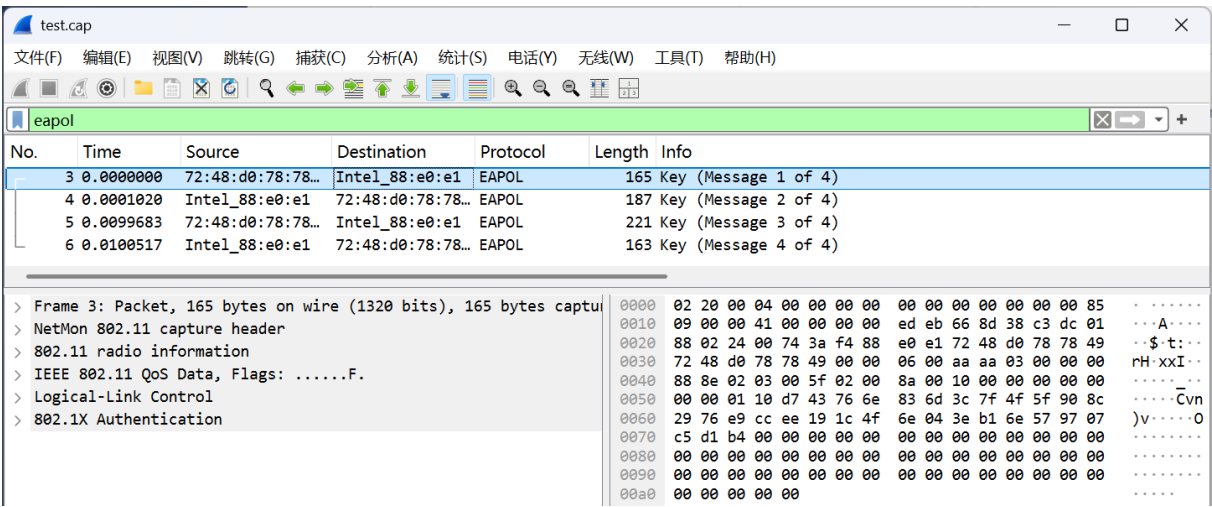


图 5: EAPOL-Key 帧

现在具体分析每一个包：

第一个：看到了有 ANonce (WPA Key Nonce 项)，但是 MIC 为全 0。

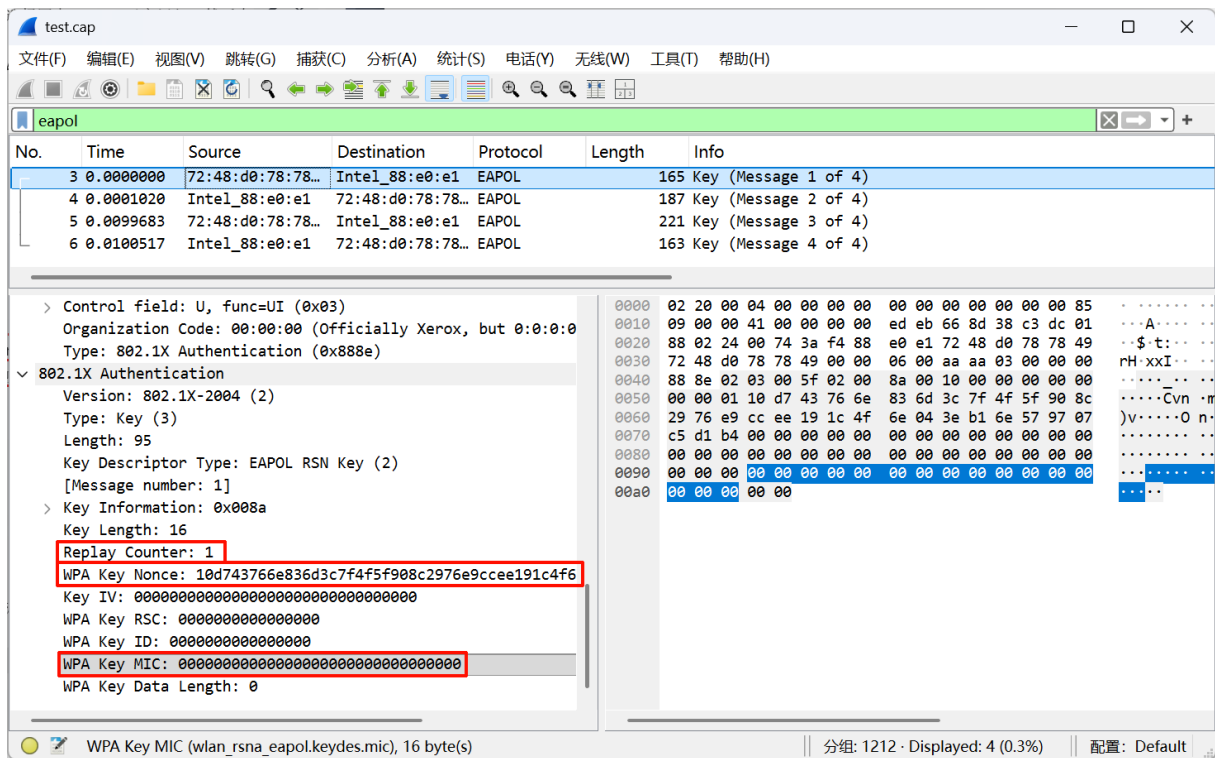


图 6: Message 1 (AP → STA)

第二个：看到了 SNonce 和 MIC。

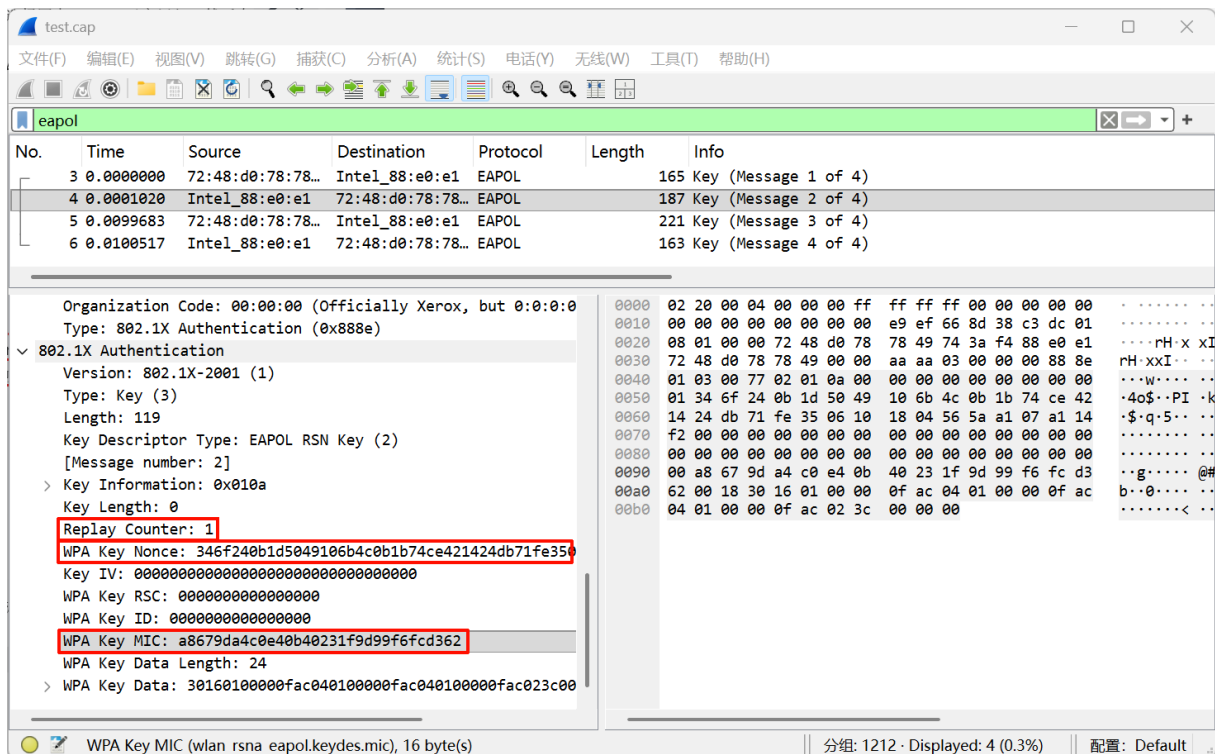


图 7: Message 2 (STA → AP)

第三个：看到了 MIC 和加密后的 GTK (WPA Key Data 项)。

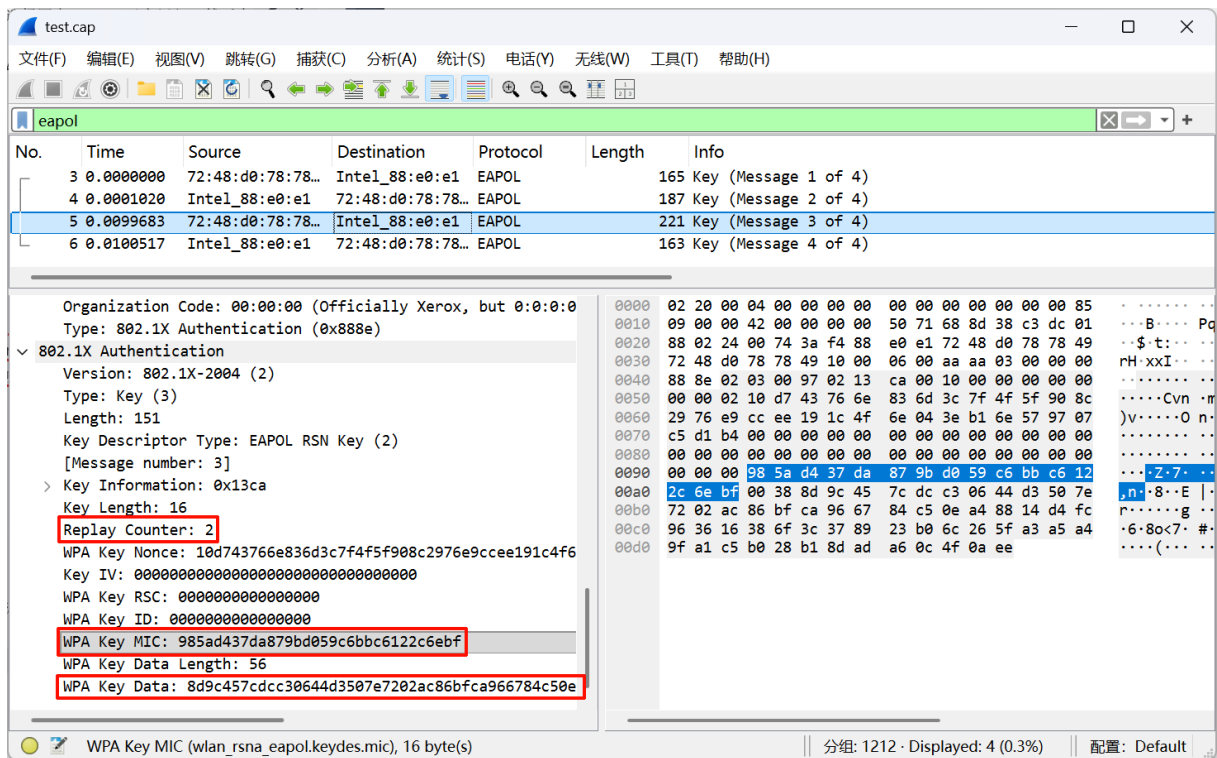


图 8: Message 3 (AP → STA)

第四个：看到了 MIC。

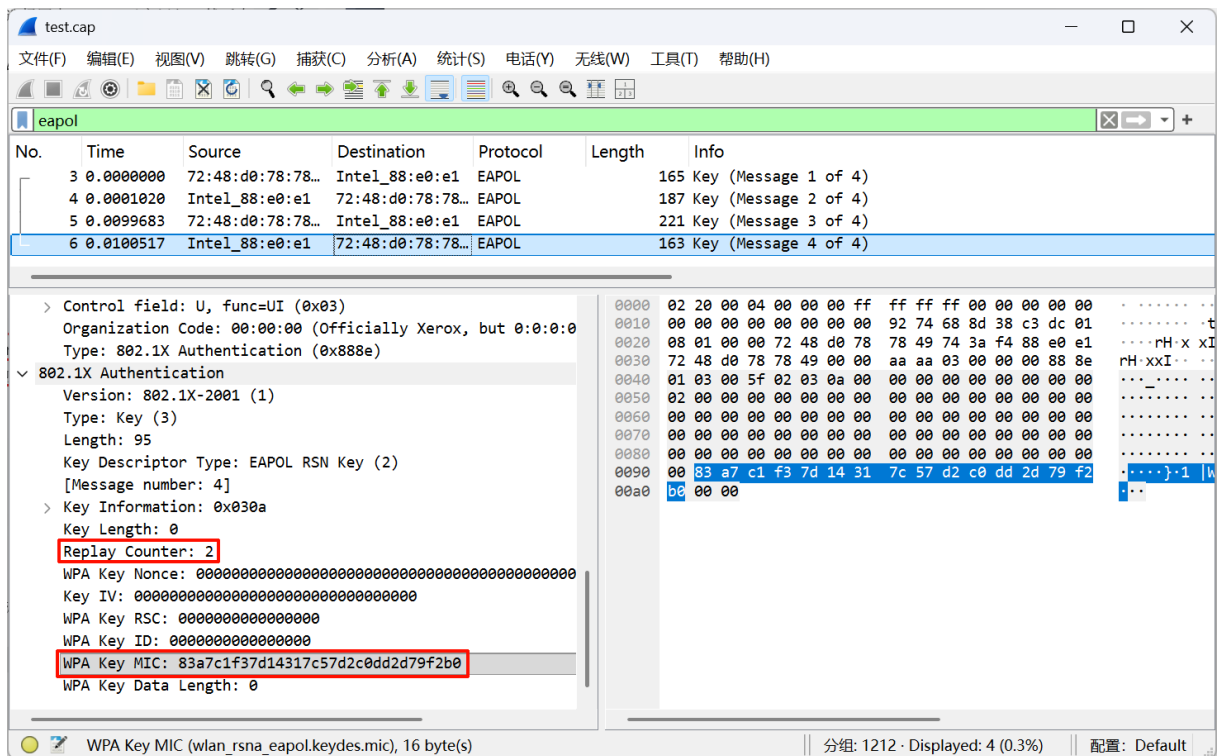


图 9: Message 4 (STA → AP)

并且发现每条消息都有 Replay Counter（重放计数器）字段，它用来防止攻击者重复发送旧的握手消息（重放攻击）。如果没有这个字段，攻击者可以抓到一次合法握手（比如 Message 3）之后反复“重放”这条消息，诱导客户端重复安装密钥。Replay Counter 用于确保消息是“当前会话的新消息”，而不是攻击者重复发送的旧数据。

6 离线字典攻击

6.1 使用 Microsoft Network Monitor 抓的包

尝试使用 Aircrack-ng 工具进行离线字典攻击。Windows 系统上需要访问官网 <https://www.aircrack-ng.org/> 下载，Kali 上自带，于是将抓到的包 test.cap 复制到 Kali 里。Kali 里自带离线字典（/usr/share/wordlists/rockyou.txt.gz），执行 `gunzip /usr/share/wordlists/rockyou.txt.gz` 解压得到 rockyou.txt（需 root 权限），如图10所示。

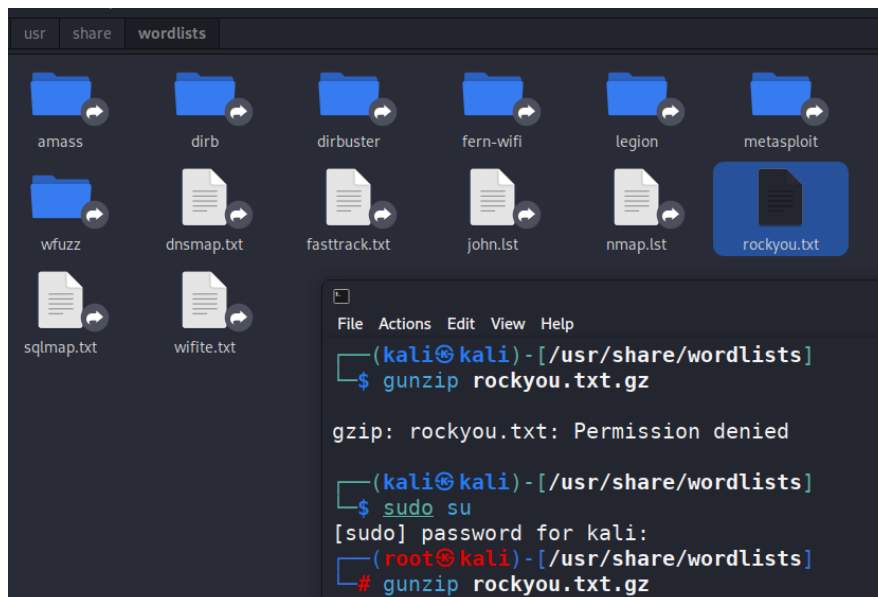


图 10: 解压离线字典

执行如下命令：

```
aircrack-ng -w /usr/share/wordlists/rockyou.txt -b 72:48:d0:78:78:49 test.cap
```

-w 后面指定字典文件，-b 后面写目标 AP 的 MAC 地址（BSSID，可以在抓包工具中看到），test.cap 是抓到的握手包。执行后显示格式不支持，如图11所示。

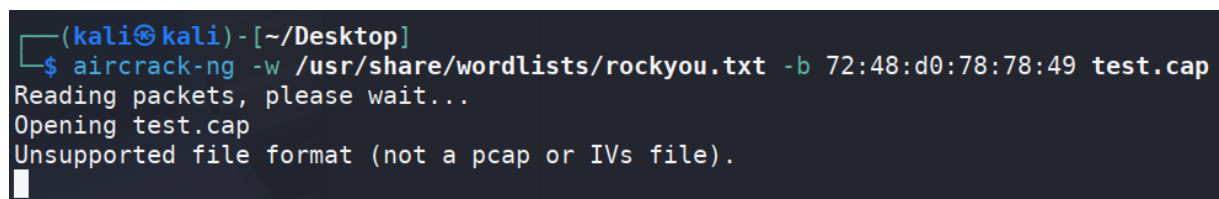


图 11: 破解失败

执行 `file test.cap`, 显示 `NetMon capture file - version 2.3 (Ethernet)`, 说明这是 Windows 的 NetMon (Network Monitor) 格式, 不是 pcap/pcapng, Aircrack-ng 不支持 NetMon。尝试使用 Wireshark 自带工具 `editcap` 将它转化为 pcap, 执行命令 `editcap -F pcap test.cap test_fixed.cap`, 显示 `editcap: The capture file being read can't be written as a "pcap" file.`, 如图12所示。很有可能是因为 NetMon 格式可以包含 Windows 特有链路层 (非标准 802.11 帧), 它是 pcap 不支持的数据类型, Aircrack-ng 工具无法进行破解。

```
(kali㉿kali)-[~/Desktop]
$ file test.cap
test.cap: NetMon capture file - version 2.3 (Ethernet)

(kali㉿kali)-[~/Desktop]
$ editcap -F pcap test.cap test_fixed.cap
editcap: The capture file being read can't be written as a "pcap" file.
```

图 12: 尝试转换格式

查了一下, 如果想要成功, 最开始应该用 Wireshark 抓包, 并且需要无线网卡支持监听模式 (一般笔记本电脑自带的无线网卡不支持, 在管理模式用 Wireshark 抓不到四次握手包)。需要购买支持监控模式的专用无线网卡或者支持监控模式的 USB 网卡才行。这里没有进一步尝试。

6.2 现有的包

老师提供了两个现有的包 `handshake_easy.cap` 和 `handshake_hard.cap`, 现在尝试进行离线字典攻击。

用 Wireshark 打开, 首先找到 AP 的 MAC 地址是 `3e:1c:ce:a3:1e:51`, 如图13所示。

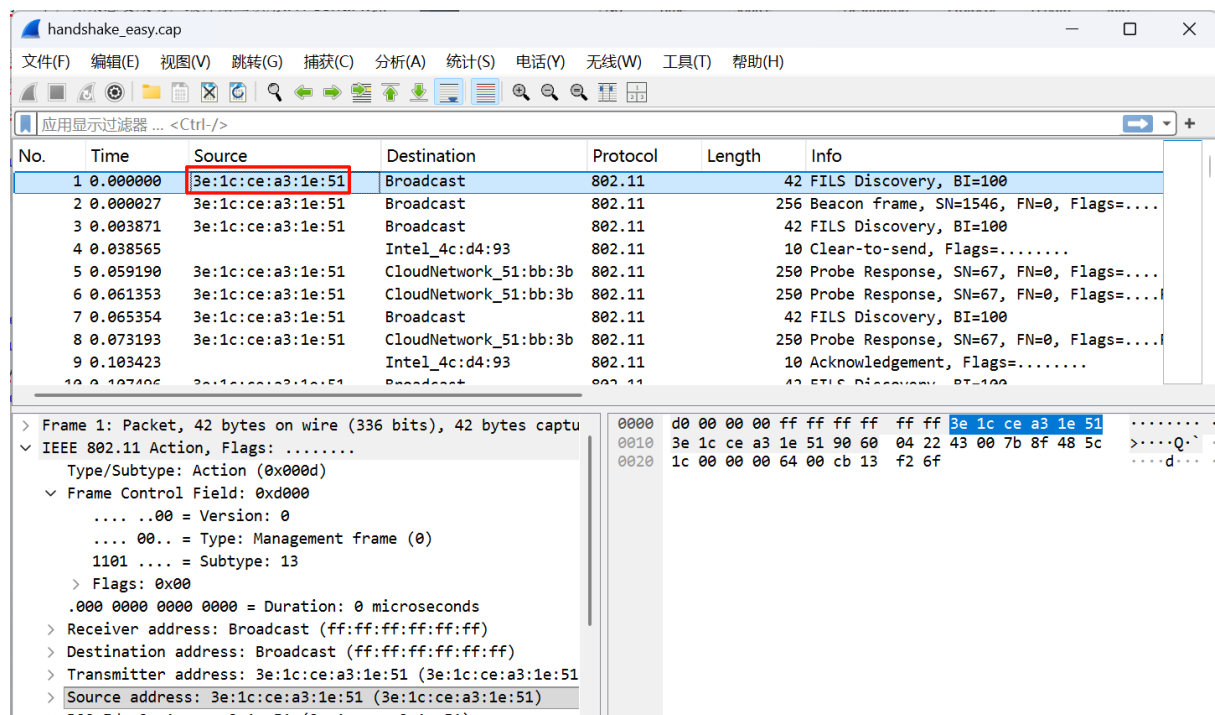


图 13: 查看 AP 的 MAC 地址

还是在 Kali 中进行破解。对于 handshake_easy.cap, 执行如下命令:

```
aircrack-ng -w /usr/share/wordlists/rockyou.txt -b 3e:1c:ce:a3:1e:51  
handshake_easy.cap
```

可以发现几秒钟就破解出来了, WiFi 密码 (PSK) 是: **159357456**, 如图14所示, 由于这是弱密码, 破解还是非常快的。

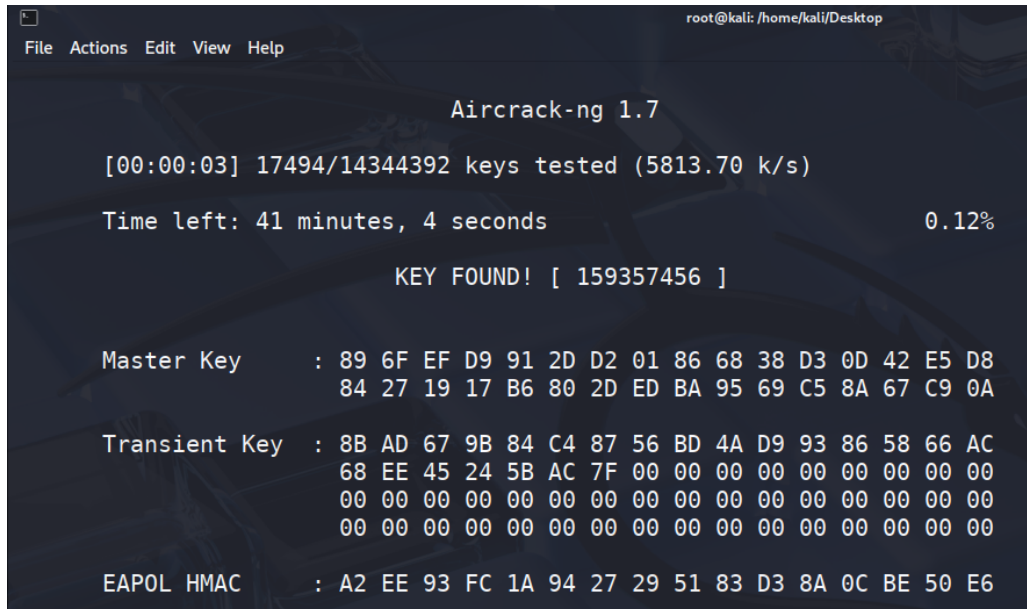


图 14: handshake_easy.cap 破解结果

用 Aircrack-ng 破解 handshake_hard.cap 发现非常慢, 所以尝试用 Hashcat。Hashcat 不能直接用.cap, 需要转换, 首先执行以下命令:

```
hcxpcapngtool -o handshake_hard.22000 handshake_hard.cap
```

将得到的 handshake_hard.22000 和字典 rockyou.txt 复制到 Windows 主机中, 在 Windows 主机里下载 Hashcat (<https://hashcat.net/hashcat/>), 下载好后解压, 进入文件夹执行:

```
hashcat.exe -m 22000 -a 0 handshake_hard.22000 rockyou.txt -w 3
```

破解了好几分钟, 但是 rockyou.txt 没包含正确密码, 所以最终破解失败了, 如图15所示。

又尝试利用了一下规则, 让 Hashcat 自动对密码进行变形:

```
hashcat.exe -m 22000 -a 0 handshake_hard.22000 rockyou.txt -r rules\best66.  
rule -w 3
```

执行后 GPU 利用率已经接近 100% 了, 风扇飞速转动, 但是最终还是没有破解出来。

总之, handshake_easy.cap 使用弱密码 **159357456** 很容易就破解了, handshake_hard.cap 使用强密码较难破解, 如果非要破解可能需要更大的字典。

```

Approaching final keyspace - workload adjusted.
Session.....: hashcat
Status.....: Exhausted
Hash.Mode.....: 22000 (WPA-PBKDF2-PMKID+EAPOL)
Hash.Target.....: handshake_hard.22000
Time.Started.....: Wed Apr 08 16:09:05 2026 (23 secs)
Time.Estimated....: Wed Apr 08 16:09:28 2026 (0 secs)
Kernel.Feature....: Pure Kernel (password length 8-63 bytes)
Guess.Base.....: File (rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 372.5 kH/s (99.56ms) @ Accel:27 Loops:512 Thr:512 Vec:1
Speed.#02.....: 58586 H/s (88.62ms) @ Accel:26 Loops:512 Thr:256 Vec:1
Speed.#*.....: 431.1 kH/s
Recovered.....: 0/1 (0.00%) Digests (total), 0/1 (0.00%) Digests (new)
Progress.....: 14344385/14344385 (100.00%)
Rejected.....: 4734913/14344385 (33.01%)
Restore.Point....: 14296389/14344385 (99.67%)
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:0-1
Restore.Sub.#02..: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: 075341832 -> *s1112m*
Candidates.#02...: %^*YUGJ_B -> $HEX[042a0337c2a156616d6f732103]
Hardware.Mon.#01.: Temp: 56c Util:100% Core:2490MHz Mem:8000MHz Bus:8
Hardware.Mon.#02.: N/A

Started: Wed Apr 08 16:08:07 2026
Stopped: Wed Apr 08 16:09:30 2026

```

图 15: handshake_hard.cap 破解结果 (字典跑完了都没有成功)

7 安全性分析

7.1 WPA2-PSK 的安全弱点及改进

WPA2-PSK 主要存在以下几个弱点:

1. **易受离线字典攻击:** 攻击者一旦捕获到四次握手中的关键报文, 就可以离线猜测口令。网络接入密码 PSK 可导出主密钥 PMK; 抓包后, 攻击者可获得 AP 与 STA 的 MAC 地址、ANonce、SNonce、EAPOL 报文中的 MIC。对每个候选密码 PSK, 攻击者都可以离线计算 MIC 并与抓到的 MIC 比较。
2. **缺乏前向安全性:** WPA2-PSK 中多个会话都依赖同一个长期共享口令。若攻击者在某一时刻获得口令, 那么过去抓取到的握手流量可被重新计算, 过去使用该口令建立的会话密钥也可能被恢复。
3. **易受 KRACK (Key Reinstallation Attack, 密钥重安装攻击):** 攻击者拦截第 4 条消息, 于是 AP 认为客户端没收到第 3 条消息, AP 重发第 3 条消息, 导致客户端再次安装密钥, nonce 被重置。在 AES-CCMP 加密算法中, 攻击者可以异或两个密文得到明文关系, 逐步恢复数据并可以注入数据包。

可以有以下改进措施:

1. **基于 PAKE 的认证改进:** 原始 WPA2-PSK 中, 主密钥通过如下方式生成:

$$PMK = PBKDF2(PW, SSID)$$

该机制允许攻击者在获取握手报文后进行离线字典攻击。

为解决该问题, 引入口令认证密钥交换 (PAKE) 机制。设双方共享口令 PW , 接入点 (AP) 与客户端 (STA) 分别生成随机数 x, y , 并交换经口令映射处理后的群元素。双方仅在口令正确时可导出一致共享秘密 K 。

随后定义主密钥:

$$PMK = \text{HKDF}(K, \text{context})$$

其中上下文信息为:

$$\text{context} = MAC_{AP} \parallel MAC_{STA} \parallel SSID \parallel N_A \parallel N_S$$

该设计保证攻击者无法从窃听数据中构造离线验证口令正确性的判定函数, 从而有效抵抗离线字典攻击。

2. **引入临时 ECDH 实现前向安全性:** 为增强前向安全性, 在认证过程中引入临时椭圆曲线 Diffie-Hellman (ECDH) 密钥交换。

具体过程如下:

- AP 生成临时私钥 a , 计算公开值:

$$A = aG$$

- STA 生成临时私钥 b , 计算公开值:

$$B = bG$$

- 双方计算共享秘密:

$$Z = abG$$

最终主密钥由 PAKE 输出 K 与 ECDH 共享秘密 Z 联合导出:

$$PMK = \text{HKDF}(K \parallel Z, \text{context})$$

该机制保证即使长期口令 PW 泄露, 攻击者在缺乏临时私钥 a, b 的情况下, 无法恢复历史会话密钥, 从而实现前向安全性。

3. **改进四次握手以防止密钥重装:** 针对四次握手中可能存在的密钥重复安装问题, 对握手过程进行如下改进。

首先定义会话标识:

$$SID = H(MAC_{AP} \parallel MAC_{STA} \parallel N_A \parallel N_S \parallel A \parallel B)$$

基于该会话标识派生会话密钥:

$$PTK = \text{HKDF}(PMK, SID \parallel \text{"PTK"})$$

握手报文中增加以下字段:

- 会话标识 SID
- 消息序号 $seq \in \{1, 2, 3, 4\}$
- 密钥安装状态标志

同时规定协议状态机约束：

- 对于每个 SID ，密钥安装操作仅允许执行一次；
- 若接收方检测到重复的 Message 3 报文，则仅允许重传确认报文，不得重新安装密钥；
- 协议状态迁移必须单调递增且不可逆；
- 所有握手消息必须绑定 SID ，防止跨会话重放。

该改进确保对任意 SID ， SID 最多只被安装一次。从而有效防止密钥重装攻击，并提升协议状态机的安全性与鲁棒性。

7.2 WPA3 对比分析

1. **SAE 握手：**WPA3-Personal 把 WPA2 的 PSK 认证换成了 SAE (Simultaneous Authentication of Equals)。SAE 基于一种称为蜻蜓密钥交换 (Dragonfly Key Exchange) 的协议。它的核心思路是验证密码的过程必须和实时通信绑定，无法脱离对方单独进行。主要流程有：

- (a) 约定元素：STA 和 AP 先用设置的 Wi-Fi 密码，通过一套确定的数学算法，各自独立计算出一个公开的“种子”点（在椭圆曲线中这个点叫 PWE, Password Element）。这个计算过程单向且不可逆。
- (b) 交换公开承诺：双方各自生成一个随机数（私密），并基于这个随机数和前一步的种子点，计算出自己的“公开承诺”发送给对方。
- (c) 验证与确认：收到对方的承诺后，双方再各自计算出一个“确认值”发送给对方，并用自己的私密随机数和对方的公开承诺，最终计算出一致的会话密钥。

在整个过程中，密码本身从未在网络中传输。攻击者只能看到公开的承诺和确认值。攻击者即使捕获了 SAE 交换的所有数据包，也无法在自己的电脑上进行离线密码猜测。因为要验证一个密码是否正确，他必须知道双方生成的私密随机数之一，而这些随机数从未传输过。他唯一能做的，是每次猜测一个密码，就必须模拟一次完整的、与实时捕获数据包相关联的复杂计算。这种“在线”模拟的代价极高，使得字典攻击变得毫无实际意义。

2. **前向安全：**WPA3 实现前向安全性的核心在于其身份认证与密钥交换协议 SAE。SAE 基于 ECDH 密钥交换：在每次连接时，STA 和 AP 各自生成一对临时的公私钥（私钥只在本次会话内存活，用完即销毁）；双方交换公钥，然后用自己的私钥和对方的公钥独立计算出相同的共享秘密（会话密钥）；Wi-Fi 密码只用于认证身份，不直接参与密钥生成。因此攻击者即使后来拿到了 Wi-Fi 密码，也无法还原出过去的临时私钥，无法计算出当时协商的会话密钥，也就无法解密任何捕获的加密流量。

3. **OWE**: Opportunistic Wireless Encryption (OWE) 是 WPA3 标准中为开放式 Wi-Fi 热点（公共场所免费 Wi-Fi）设计的一种无密码加密技术。OWE 基于 Diffie-Hellman 密钥交换，让双方独立计算出相同的临时密钥（PMK），进而派生用于数据加密的 PTK。由于 OWE 没有认证机制，它无法防御中间人攻击。

WPA2 与 WPA3 在安全性方面的对比如下：

比较方面	WPA2	WPA3
认证机制	采用 PSK (Pre-Shared Key, 预共享密钥) 认证机制。用户口令直接参与主密钥派生，攻击者一旦捕获四次握手报文，即可离线猜测密码并验证其正确性，因此容易受到离线字典攻击，尤其是在口令强度不足时风险较高。	采用 SAE (Simultaneous Authentication of Equals) 认证机制，属于基于口令的认证密钥交换方法。SAE 不再像 WPA2 那样向攻击者暴露可直接用于离线验证口令正确性的握手材料，从而显著增强了对离线字典攻击的抵抗能力。
前向安全	不具备前向安全性。 由于多个会话的安全性都与同一个长期共享口令相关，一旦攻击者在未来获得该口令，就可能利用之前抓取的握手数据恢复历史会话密钥，进而解密过去的通信内容。	具备前向安全性。 WPA3 中 SAE 在每次认证过程中都会协商生成新的共享秘密，会话密钥不再仅仅依赖长期口令。因此，即使长期口令在之后泄露，也不能直接用于恢复先前会话的加密内容。
开放网络保护	传统开放网络通常 不提供链路层加密保护 。用户接入无需密码，但无线数据往往以明文方式在空中传输，攻击者可以较容易地进行被动窃听，因此安全性较低。	引入了 OWE (Opportunistic Wireless Encryption, 机会式无线加密) 机制，用于开放网络场景。OWE 允许终端与接入点在无口令条件下协商出会话密钥，从而对无线链路进行加密，显著提高了开放网络中的通信保密性；但其主要提供的是加密保护， 不提供身份认证 。

8 总结与思考

通过本次 WPA/WPA2 协议分析实验，我深入理解了四次握手的完整流程以及 EAPOL-Key 帧中各字段（如 ANonce、SNonce、MIC、Replay Counter 等）的实际作用。使用 Microsoft Network Monitor 成功捕获了手机热点连接时的四次握手包，并借助 Wireshark 进行了逐帧分析，加深了对密钥派生和完整性校验机制的认识。在尝试进行离线字典攻击时，由于抓包文件为

NetMon 专用格式，未能成功转换为 aircrack-ng 支持的 pcap 格式，应使用支持监控模式的无线网卡配合 Wireshark 直接捕获标准 802.11 帧。此外，通过对 WPA2-PSK 弱点的梳理以及与 WPA3 的对比，我更加清晰地看到 SAE 协议在抵抗离线字典攻击、提供前向安全性以及 OWE 加密开放网络等方面的显著改进。